

spotify-step-2-1-policy-document--v14--annexes

SPOTIFY DATA & AI GOVERNANCE PROJECT

2.1. Data & AI Governance Policy Document

Nicolas Pichon - AIA RNCP 38777 / BC01 / Step 2.1 / v14 - 2026/10/13.

Annexes

2.1.A. Comment la politique de gouvernance répond aux enjeux majeurs identifiés en évaluation

Le tableau ci-dessous relie les enjeux majeurs identifiés dans [D1] aux dispositions de la présente politique.

#	Enjeu	Dispositions de la politique qui y répondent
E1	Décompartimenter les données	Responsabilité par actif (P1) ; Rôles DO/DS à double rattachement (§2.1.6 & [D22]) ; Standardisation de la qualité (P4)
E2	Maîtriser la qualité des données	Règles de qualité mesurables et audits (P4) ; Traitement spécifique des données d'apprentissage (§2.1.5)
E3	Maîtriser la mise en conformité réglementaire dans un contexte multi-juridictionnel	P5 ; Socle GDPR/CCPA/PCI-DSS (§2.1.4) ; Processus de cartographie réglementaire par marché piloté par DPO/Legal Team (§2.1.4)
E4	Garantir la vie privée et l'usage éthique des données	Transparence (P2) ; Minimisation (P6) ; Droits et anonymisation (P7) ; Ethique (P8) ; biais, explicabilité (§2.1.5)
E5	Gouverner spécifiquement les données IA	P8 ; Traçabilité, biais, approbation des modèles, explicabilité (§2.1.5) ; Rôles MO & MRM (§2.1.6).
E6	Accompagner la montée en compétences data	Responsabilité partagée (P1) ; Intégration des rôles de métier comme parties prenantes de la gouvernance (§2.1.6) ; Amélioration continue (P9).

2.1.B. Comment la politique de gouvernance répond aux actions attendues le guide des principes e gouvernances

Le tableau ci-dessous relie les actions de principe attendues dans le guide [R4] aux dispositions de la présente politique.

#	Principe	Action attendue	Enjeux servis	Réponse de la politique	
P1	Responsabilité	Définir les rôles et responsabilités de propriété et de responsabilité des données	E1, E6	Rôles DO / DS / MO définis et opérationnalisés dans l'organigramme [D22] ; la chaîne CDO / DO / DS évite le silotage (E1), le partage de rôles entre métiers diffuse la responsabilité (E6).	
P2	Transparence	Mettre en place des mentions d'information et une gestion du consentement conformes	E4 (E3)	§2.1.4 (consentement explicite GDPR, opt-out CCPA) ; étendue à la transparence sur la collecte, l'usage et le partage (E4).	
P3	Sécurité	Garantir contrôle d'accès approprié, chiffrement, protocoles de réponse aux violations	(transversal E3, E4)	P3 (chiffrement, accès par rôle, PCI-DSS) ; réponse aux violations au §2.1.4. Principe transversal, sans enjeu majeur dédié dans [D1].	
P4	Qualité	Établir des indicateurs de qualité et mettre en œuvre des audits réguliers	E2, E1	P4 (règles mesurables auditées) ; Responsabilités définies dans [D22].	

#	Principe	Action attendue	Enjeux servis	Réponse de la politique	
P5	Conformité	Réaliser des revues régulières pour suivre l'évolution des lois de protection des données	E3	P5 (veille légale) ; enjeu multi-juridictionnel pris en compte par la cartographie réglementaire (§2.1.4).	
P6	Minimisation	Mettre en oeuvre des politiques de collecte strictes et minimisées	E4	P6 (collecte limitée au nécessaire) + anonymisation ; réduit l'exposition au risque et la matière première des inférences intrusives.	
P7	Droits des utilisateurs	Mettre en place des systèmes permettant l'exercice de ces droits	E4	P7 + §2.1.4 (accès, modification, suppression, opposition) ; Responsabilités définies dans [D22] (<i>DPO "Accountable"</i> sur les demandes)	
P8	Usage éthique	Garantir l'intégration de lignes directrices éthiques dans les projets data & IA	E5, E4	Transformé en quatre exigences concrètes au §2.1.5 (lineage, biais, approbation, explicabilité), opérationnalisées par les rôles MO / MRM de [S22]	
P9	Amélioration continue	Revoir et actualiser régulièrement le cadre de gouvernance, en intégrant les retours et bonnes pratiques	E6 (transversal)	Revue périodiques au §2.1.7, rendues mesurables par la méthodologie DMAT [R1] et par un objectif chiffré (niveau 1 > niveau 3)	